Technical University of Denmark

Written examination, December 19, 2025

Course name: Cybersecurity Fundamentals

Course number: 02270

Aids allowed: No Aid

Exam duration: 2 hours

Weighting:

- The exam contains 25 multiple choice questions.
- Each question has answer choices A, B, C, and D. Exactly one of them is the correct answer.
- You must mark only one answer for each question on the answer sheet. The correct answer gives 1 point, a wrong answer or marking multiple answers gives 0 points.
- You can also choose "E. Don't know", but since there are no negative points for wrong answers, it is recommend to take your best guess of choice A, B, C, and D, if you do not know an answer.

Enjoy and have a great success!

1 Cryptography

Question 1: Hashing algorithms

Which of the following is *incorrect* regarding cryptographic hash functions

A. Given a message M, computing its hash value h = H(M) must be easy.

B. Given a hash value h, it must be computationally intractable to find an M such that H(M) = h.

C. It must be easy to find two different messages M and M' such that H(M) = H(M').

D. A hash value is often referred to as a "digest" or "fingerprint" of the message

Question 2: Double Encryption

A company decides to encrypt all files using AES-128, and then encrypts the AES ciphertext AGAIN with RSA-2048 to "double" security. Which of the following statements is "*correct*"?

A. RSA cannot encrypt symmetric ciphertext

B. RSA encryption adds no meaningful security when used over large data and reduces performance

C. AES-128 is too weak

D. Double encryption always results in weaker security

Question 3: Encryption schemes

A door-access system uses symmetric keys shared between badges and the central server. The badge sends an encrypted token every time it is used, but the token is always the same for a given badge. Attackers capture the token and replay it to unlock doors. What is the main design flaw?

A. Using symmetric keys

B. Not using asymmetric keys

C. Lack of nonces or freshness in symmetric encryption

D. Using encryption instead of hashing

Question 4: Digital Signature

Which statement about digital signatures is *correct*?

A. They encrypt the entire message.

B. They guarantee the message will remain confidential.

C. They verify the sender's identity.

D. They prevent all types of cyber attacks.

Question 5: Non-repudiation

What is the main purpose of non-repudiation in cybersecurity?

A. To prevent modifications to data

B. To prove that a specific entity performed a specific action

C. To keep information secret from unauthorized users

D. To detect attacks in real time

Question 6: Protocols

A multinational company is implementing a secure communication workflow between two subsidiaries. They do not trust each other fully but agree to trust a third-party organization that will monitor and validate message exchanges. Which type of protocol is most appropriate?

A. Self-enforcing protocol

B. Arbitrated protocol

C. Adjudicated protocol

D. Peer-to-peer protocol

2 Protocol Security

Question 7: TLS

We have discussed in the lecture how the TLS protocol works. Which of the following statements about TLS is correct?

A. TLS requires that client and server know each other's public key in advance.

B. TLS requires that the client knows the server's public key in advance.

C. TLS requires that the client authenticates its Diffie-Hellman share.

D. TLS requires that the server authenticates its Diffie-Hellman share.

Question 8: An Example Protocol

Consider the following protocol:

```
Protocol: prot

Types: Agent A,B;
       Function pk,sk;
       Symmetric_key K;
       Number Msg;
Knowledge:
A: A,B,pk(B),sk(A,B);
B: A,B,pk(B),inv(pk(B)),sk(A,B)

Actions:
A->B: {A,B,K,sk(A,B)}pk(B)
B->A: {| Msg |}K

Goals:
Msg secret between A,B
B authenticates A on K
A authenticates B on Msg
sk(A,B) guessable secret between A,B
```

OFMC finds the following attack trace:

```
ATTACK TRACE:
(x502,1) -> i: {x502,x501,K(1),sk(x502,x501)}_(pk(x501))
i -> (x501,1): {x502,x501,K(1),sk(x502,x501)}_(pk(x501))
(x501,1) -> i: {|Msg(2)|}_K(1)
i -> (x501,2): {x502,x501,K(1),sk(x502,x501)}_(pk(x501))
(x501,2) -> i: {|Msg(3)|}_K(1)
```

Which goal is violated as demonstrated by this attack trace?

A. `Msg secret between A,B`

B. `B authenticates A on K`

C. `A authenticates B on Msg`

D. `sk(A,B) guessable secret between A,B`

Question 9: Fixing the Example Protocol

How can the attack from the previous protocol be fixed?

A. B should generate a fresh number and include it in the second message.

B. The names of A and B should be included in the second message.

C. The second message should be signed by B.

D. None of the above answers solves the problem.

Question 10: Single Sign-On

What is the purpose of a Single Sign-On protocol?

A. A client can authenticate itself to servers with whom they have no prior security relationship like username/password.

B. A client is prevented from using the same password with different servers.

C. Single Sign-On is a replacement for national identity solutions like MitID.

D. Single Sign-On ensures unlinkability of different sessions.

3 Privacy

Question 11: Onion Routing

Consider an onion routing network with nodes N_1 to N_{10} and suppose Node N_1 sends a message M to Node N_{10} via intermediate nodes N_3, N_4, and N_5. Suppose that traffic analysis is impossible (all nodes create sufficient dummy traffic et cetera). Which of the following statements is correct?

A. N_{10} can see that M originates from N_1

B. N_3 can see that M originates from N_1

C. If one of the intermediate nodes N_3, N_4, or N_5 is honest, then the path from N_1 to N_{10} cannot be observed by an attacker.

D. If one of the intermediate nodes N_3, N_4, or N_5 is dishonest, then the path from N_1 to N_{10} can be observed by an attacker.

Question 12: Zero-Knowledge Proofs

Consider the Schnorr protocol from the lecture, where the verifier Victor knows a public value Z and the prover Peggy wants to convince Victor that show knows a value X such that $Z = g^X \bmod p$.
Which of the following statements is true about the protocol?

A. If Peggy runs the protocol several times with the same commitment value, then Victor can learn X.

B. If Victor runs the protocol several times with the same challenge, then Peggy can learn Z.

C. If Pamela does not know X, then her chance to convince Victor in N rounds of the protocol is 2^{-N}.

D. The chance that Victor learns X in N rounds of the protocol is 2^{-N}.

4 Authentication

Question 13: Identity Management Models

A multinational company provides SSO for all internal applications. However, when employees need to access partner-company systems, they use identity federation protocols such as SAML or OpenID Connect to authenticate using their corporate credentials. What combination of identity models is used here?

A. SSO internally, Federated Identity externally

B. Identity Silos internally, SSO externally

C. Federated Identity internally, SSO externally

D. Only Federated Identity

Question 14: Kerberos

The Key Distribution Center (KDC) in Kerberos consists of

A. Authentication Server (AS) and Service Server (SS)

B. Key Server and Authentication Gateway

C. Ticket-Granting Server (TGS) and Service Server (SS)

D. Authentication Server (AS) and Ticket-Granting Server (TGS)

5 Access Control

Question 15: Access Control Matrix

DTU uses an access control system to manage access to its digital resources.

- The system has students, faculty, and administrators as users.
- Resources include Grades, Course Materials, and Admin Panel.
- Different departments (e.g., Compute, Physics) and contextual conditions (e.g., time, location) may also affect access.

DTU wants to ensure that

- Each user can only access what is permitted to them.
- Access can be controlled based on roles, individual identities, and attributes like department or time.

DTU defines the following policy:

- Professors can upload grades and course materials.
- Students can view only their own grades and materials.
- Access to the system is denied outside university hours (8 AM – 8 PM).

Which access control model best represents this policy?

A. A. Identity-Based Access Control (IBAC) – because permissions are tied to specific users.

B. Role-Based Access Control (RBAC) – because permissions depend on user roles such as "Professor" or "Student".

C. Attribute-Based Access Control (ABAC) – because the system considers attributes like department and time of access

D. Combination of RBAC and ABAC – because access depends on both user roles (Professor/Student) and environmental conditions (time).

Question 16: Multilevel Security

Which of the following rule pairs correctly represents the Bell–LaPadula and Biba models?

A. Bell–LaPadula: No Read Down, No Write Up – Biba: No Read Up, No Write Down

B. Bell–LaPadula: No Read Up, No Write Down – Biba: No Read Down, No Write Up

C. Bell–LaPadula: No Read Up, No Write Up – Biba: No Read Down, No Write Down

D. Bell–LaPadula: No Read Down, No Write Down – Biba: No Read Up, No Write Up

6 Network Security

Question 17: Communication Security

Which of the following statements *best* describes end-to-end (E2E) encryption in communication security?

A. Encryption is applied only during transmission, and routers perform decryption and re-encryption at each hop

B. Data is encrypted at the application layer by the sender and remains encrypted until it reaches the final receiver.

C. Encryption is performed by intermediate network devices, ensuring faster routing and bandwidth optimization

D. Data is encrypted by the network provider, allowing it to read and inspect communications for security purposes.

Question 18: Network Segmentation

Which of the following *best* describes the role of network segmentation in cybersecurity?

A. A method to encrypt all traffic end-to-end.

B. A technique to isolate network zones, limit lateral movement, and enforce granular access controls.

C. A tool to automatically block external attacks at the perimeter.

D. A way to centralize all traffic for easier monitoring.

7 Governance

Question 19: Risk

PharmaCare Ltd. is developing a new vaccine. Due to tight timelines, the Quality Assurance (QA) team initiates a Quality Risk Management Process to ensure product safety and compliance.
They follow these steps:

- **Risk Identification:** The team lists potential risks like contamination during production, supply chain delays, and data integrity issues.
- **Risk Analysis:** Each risk is analyzed for likelihood and impact. Contamination has high impact but low likelihood; supply chain delays have medium impact and high likelihood.
- **Risk Evaluation:** The team categorizes risks as acceptable or unacceptable based on company policy and regulatory guidelines.
- **Risk Control:** For unacceptable risks, they plan mitigation strategies. For contamination risk, they implement enhanced sterilization procedures (Risk Reduction). For supply chain delays, they accept the risk but create contingency plans (Risk Acceptance).
- **Risk Review:** They regularly review events such as audit findings and deviations to ensure risk controls remain effective.

During the risk evaluation step, PharmaCare finds a risk with high likelihood but low impact. According to the process, what should the team do next?

A. Immediately reduce the risk regardless of cost.

B. Accept the risk or monitor it depending on company tolerance.

C. Ignore the risk because it has low impact.

D. Restart the entire risk management process.

Question 20: Security Policy

During a post-incident review, investigators discover that a recently deployed endpoint detection tool generated thousands of alerts per day across business units. No tuning process, escalation criteria, or threshold definitions were planned, so analysts routinely dismissed alerts. Which planning principle failed?

A. Implement defense-in-depth

B. Develop operational procedures and lifecycle maintenance plans

C. Enforce least-privilege architecture

D. Ensure cryptographic key rotation policies

8 Software Security

Question 21: Links

An attack occurred in an accounting system of a company. Analysis shows that after a specific financial transaction was executed, a malicious payload was triggered that deleted several records and sent false reports. What type of malware is the *most likely* cause of the attack?

A. A Trojan horse

B. A Logic bomb

C. A Rootkit

D. A Worm

Question 22: Buffer Overflow

Which of these statements about buffer overflows is *incorrect*?

A. The buffer overflow problem is partly caused by the way the C language handles memory management.

B. The buffer overflow problem is partly caused by C programmers not handling their own memory management properly by checking boundaries of buffers.

C. All buffer overflows are simple programmer errors that are easily spotted.

D. Because of the complexity of the problem, buffer overflows may be overlooked by the most seasoned programmers.

9 Social Engineering

Question 23: Phising

A SOC analyst notices a spike in failed VPN logins from an employee's account at 2:11 AM.

At 2:15 AM, a successful login occurs from an IP located in another country.
Reviewing ticket logs, the analyst finds that earlier that day the employee contacted the helpdesk stating:

"IT support called me asking me to read the OTP they sent, so they could confirm my account wasn't compromised."

Firewall logs show traffic to a suspicious domain immediately after the successful login.

What type of attack chain *best* explains the compromise?

A. Malware infection → DNS poisoning → Credential stuffing.

B. Vishing → MFA fatigue → VPN compromise

C. Vishing → OTP harvesting → Account takeover

D. Phishing → Man-in-the-middle → Password spraying

Question 24: Social Engineering

An employee receives a phone call from someone claiming to be from their bank, asking to verify their account details for security purposes. What type of attack is this?

A. Phishing.

B. Vishing

C. Smishing

D. Tailgating

10 Legal Aspects

Question 25: GDPR

A company wants to ensure its board is aware of data privacy risks, maintains a risk register, and assigns clear accountability for data protection. Which of the following *best* describes this activity?

A. Data inventory

B. Governance framework establishment

C. Penetration testing

D. Privacy impact assessment